Capstone Project – Week 2 Report

Project: Security Posture Assessment and Risk Plan for a Small Organization.

Week 2: 9 to 13 November 2026.

Author: Lola Rouquet.

1-Summary

The three machines were audited and a gap analysis was written for each one. The audits were run on 6 November 2026, ahead of the plan. Week 2 was used to analyze the results against CIS Controls v8 and set priorities.

Main result: six High gaps in total, four on the file server (M02) and two on the employee laptop (M01). The Kali workstation (M03) has no High gap. These gaps are the starting point of the Week 3 risk register.

2-How the audits were done

Machine	Tool	How it was run	Result saved in
M01 – Windows 11 laptop (DESKTOP-TVVAHP9)	HardeningKitty 0.9.4	Audit mode, CIS Windows 11 Enterprise 24H2 list (closest list for build 26300, see Week 1 report), PowerShell as administrator	M01_HardeningKitty_report_20261106.csv
M02 – Ubuntu file server (fileserver01)	Lynis 3.0.9	sudo lynis audit system	/var/log/lynis.log and /var/log/lynis-report.dat on the server
M03 – Kali audit workstation (kali)	Lynis 3.1.6	Full system audit	M03_Lynis_output_20261106.txt

• Both tools only read settings. Nothing was changed on any machine.

• The two tools used different tests and different scales: Lynis gives a hardening index out of 100 (M02, M03), HardeningKitty a score from 1 to 6 (M01). So the Windows score can't be compared with the two Linux scores. Only M02 and M03 can be compared, because both were audited with Lynis.

3-Audit results

Machine	**Score**	**Tests**	**Findings**
M01 – Windows laptop	3.29 out of 6	647 checks	165 passed, 482 failed (43 Low, 439 Medium, 0 High)
M02 – Ubuntu file server	57 out of 100	252 tests	2 warnings, 38 suggestions
M03 – Kali workstation	61 out of 100	271 tests	0 warnings, 47 suggestions

Each screenshot below is the evidence for one result. All six are also in W2_Screenshots.

3.1 M02- Ubuntu file server

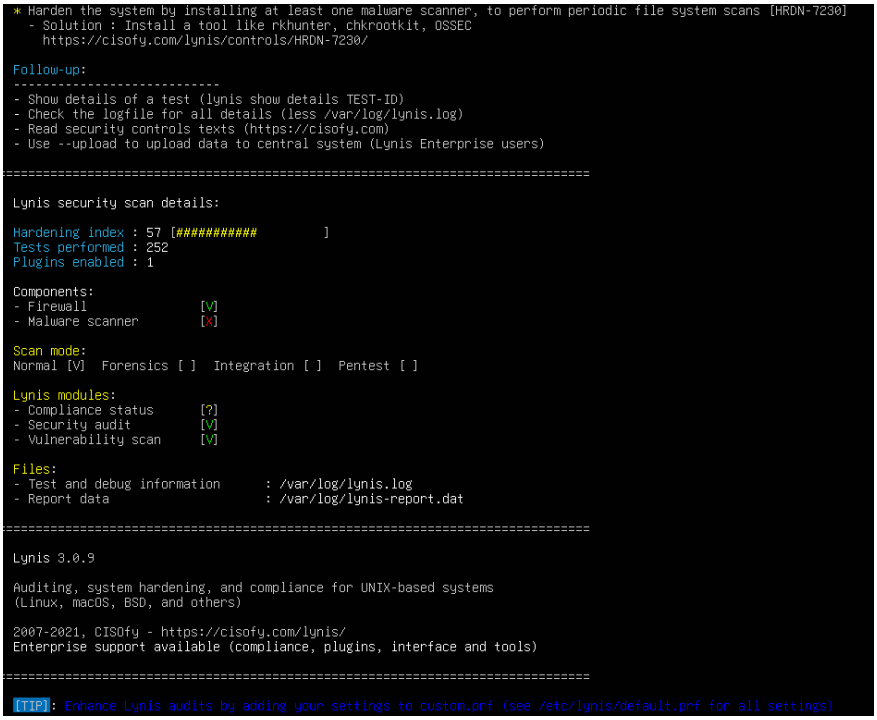


Figure 1- Lynis audit summary, M02 (fileserver01), 6 November 2026.

What it shows: the end of the Lynis audit. Hardening index 57, 252 tests performed, Lynis version 3.0.9. A firewall is installed ([V]), but it has no active rules (see Figure 2). There is no malware scanner ([X]). The full results are saved in /var/log/lynis.log and /var/log/lynis-report.dat.

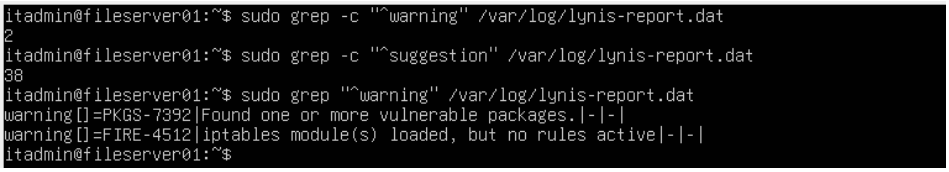


Figure 2- Lynis warnings and suggestions count, M02.

What it shows: grep -c counts the lines starting with “warning” and “suggestion” in the Lynis report file: 2 warnings and 38 suggestions. The third command lists the two warnings: vulnerable packages installed (PKGS-7392) and a firewall module loaded with no active rules (FIRE-4512).

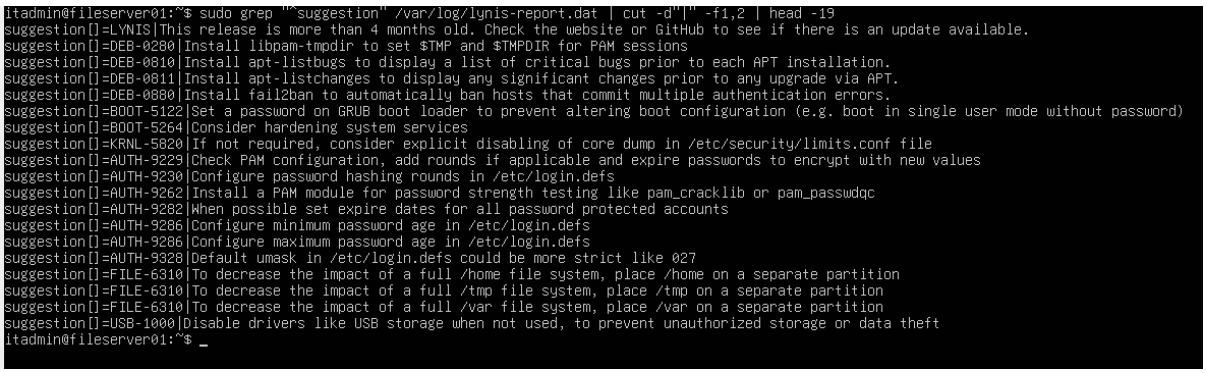


Figure 3- Lynis suggestion 1 to 19, M02.

What it shows: the first 19 of the 38 suggestions, with their Lynis IDs (for example AUTH-9262: no password strength check).

```
ltadmin@fileserver01:~$ sudo grep "^suggestion" /var/log/lynis-report.dat | cut -d"|" -f1,2 | tail -19
suggestion[]=NAME-4028|Check DNS configuration for the dns domain name
suggestion[]=PKGS-7370|Install debsums utility for the verification of packages with known good database.
suggestion[]=PKGS-7392|Update your system with apt-get update, apt-get upgrade, apt-get dist-upgrade and/or unattended-upgrades
suggestion[]=PKGS-7394|Install package apt-show-versions for patch management purposes
suggestion[]=NETW-3200|Determine if protocol 'dccp' is really needed on this system
suggestion[]=NETW-3200|Determine if protocol 'sctp' is really needed on this system
suggestion[]=NETW-3200|Determine if protocol 'rds' is really needed on this system
suggestion[]=NETW-3200|Determine if protocol 'tipc' is really needed on this system
suggestion[]=LOGG-2154|Enable logging to an external logging host for archiving purposes and additional protection
suggestion[]=BANN-7126|Add a legal banner to /etc/issue, to warn unauthorized users
suggestion[]=BANN-7130|Add legal banner to /etc/issue.net, to warn unauthorized users
suggestion[]=ACCT-9622|Enable process accounting
suggestion[]=ACCT-9626|Enable sysstat to collect accounting (disabled)
suggestion[]=ACCT-9628|Enable auditd to collect audit information
suggestion[]=FINT-4350|Install a file integrity tool to monitor changes to critical and sensitive files
suggestion[]=TOOL-5002|Determine if automation tools are present for system management
suggestion[]=FILE-7524|Consider restricting file permissions
suggestion[]=KRNL-6000|One or more sysctl values differ from the scan profile and could be tweaked
suggestion[]=HRDN-7230|Harden the system by installing at least one malware scanner, to perform periodic file system scans
ltadmin@fileserver01:~$
```

Figure 4- Lynis suggestions 20 to 38, M02.

What it shows: the last 19 suggestions (for example HRDN-7230: no malware scanner). Figure 3 and 4 together show all 38 suggestions used in the M02 gap analysis.

3.2 M01- Windows 11 laptop

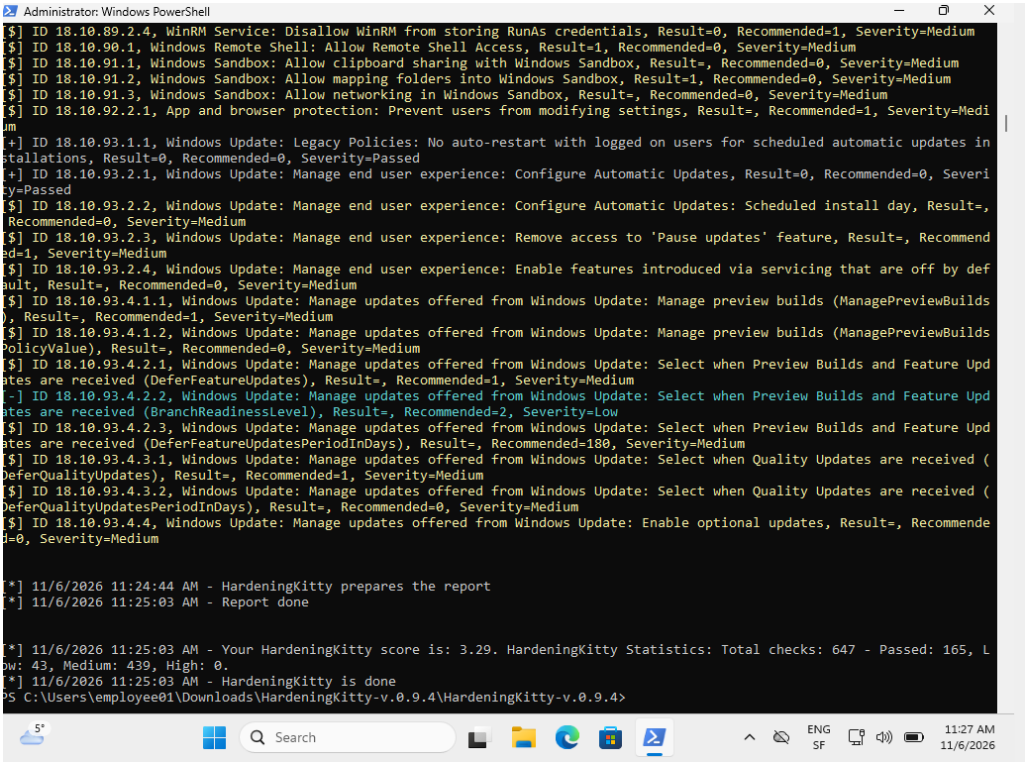


Figure 5- HardeningKitty audit summary, M01 (Windows 11), 6 November 2026.

What it shows: the end of the HardeningKitty audit, at 11:25. Score 3.29, 647 checks: 165 passed, 43 Low, 439 Medium, 0 High. Each line above is one check: [+] = passed, [-] = Low finding, [$] = Medium finding. Each line gives the value found (Result) and the CIS value (Recommended).

3.3 M03- Kali audit workstation

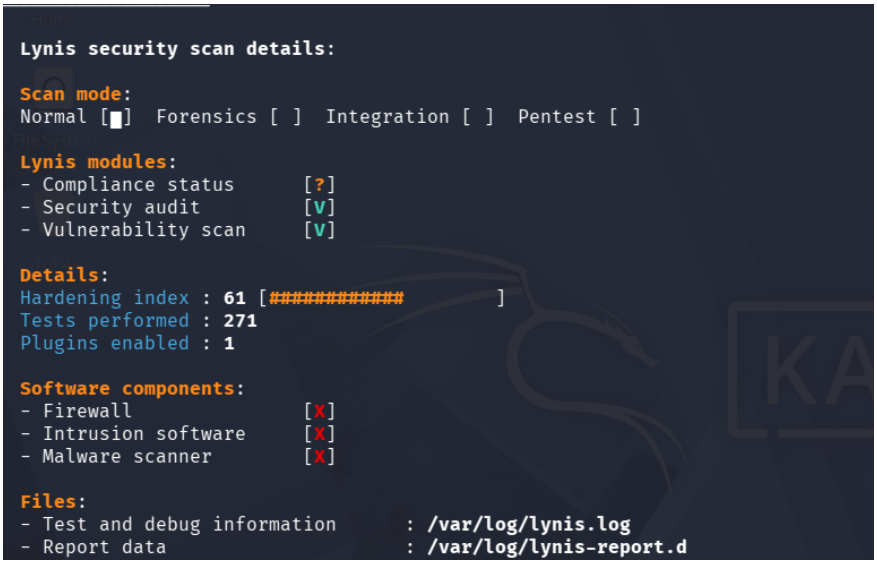


Figure 6- Lynis audit summary. M03 (Kali), 6 November 2026.

What it shows: hardening index 61 and 271 tests performed. No firewall, no intrusion software and no malware scanner were found ([X]). The counts of 0 warnings and 47 suggestions come from the full output saved in M03_Lynis_output_20261106.txt.

4- Gap analysis

One gap analysis was written for each machine. Each one follows the same four steps:

• **Group**: the findings are grouped by subject (for example all password findings together).

• **Link**: each group is linked to one CIS Control v8. When no control fits exactly the closest one is used and marked “closest”.

• **Compare**: what CIS expects, what the audit found and the gap.

• **Prioritize**: High = a basic protection is missing and client or payroll data is directly exposed; Medium = an extra layer is missing; Low = limited impact. The same rule is used for all three machines.

Machine	Findings	Groups (numbers used in each gap analysis)	High gaps
M01 – Windows laptop	482 failed checks	13 (W1–W13)	2: weak password rules (W1), disk encryption not enforced by policy (W4)
M02 – Ubuntu file server	2 warnings, 38 suggestions	12 (G1–G12)	4: missing updates (G1), firewall without rules (G2), weak password rules (G3), no malware scanner (G4)
M03 – Kali workstation	47 suggestions	12 (K1–K12)	0: Kali holds no client or payroll data, so its missing basic protections are Medium

Full documents (on GitHub): W2_Gap_Analysis_M01, W2_Gap_Analysis_M02, W2_Gap_Analysis_M03.

5-Main result

• The file server (M02) comes first: it holds payroll and client records and has four High gaps.

• The same basic problem appears on all three machines: weak password rules (M01 W1, M02 G3, M03 K3).

• No malware scanner was found on either Linux machine (M02 G4, M03 K4).

6-Issues met and how they were solved

• **Too many Windows results to read one by one:** 482 failed checks were grouped into 13 themes, starting from the categories HardeningKitty already uses.

• **What the Windows audit can prove**: Hardeningkitty reads settings only. It doesn't test whether the firewall is running or whether the disk is encrypted. The M01 gap analysis says "not enforced by policy", never "off".

• **Kali "warning" on screen**: Lynis showed [WARNING] for home directory permissions during the scan, but listed it at the end as a suggestion (HOME-9304). The official count stays at 0 warnings.

• **Moving the Windows results out of the VM**: the CSV file was opened in Notepad and copied out with the VirtualBox shared clipboard.

7-Plan for Week 3

• Build the risk register from the High and Medium gaps, including the dependence on external providers (email and accounting software).

• Write a short Acceptable Use Policy for the staff.

• Draft the remediation roadmap: what to fix first, based on the priorities above.

8. Sources

• **Audit evidence**: W2_Screenshots (Figures 1 to 6); M01_HardeningKitty_report_20261106.csv; M03_Lynis_output_20261106.txt.

• **Lynis**: cisofy.com/lynis; each test ID explained at cisofy.com/lynis/controls/<ID>.

• **HardeningKitty**: github.com/scipag/HardeningKitty (tool, score method and CIS lists).

• **CIS Controls v8**: cisecurity.org/controls/cis-controls-list.

• **Method note**: no official mapping exists between the tools and CIS Controls; linking each group to a CIS Control is my own analysis.